

GRC102 – Information Security Governance

Week 4 Practical Laboratory Report

Linux Security Monitoring and Audit Report

Student Name	Abigail Silas
Registration Number	C11/26/CGRCE/17260
Course	GRC102 – Information Security Governance
Module	Module 4 – Monitoring and Auditing Security Controls
Role	Security Control Assurance Analyst
Lab Environment	Kali Linux (personal authorised lab VM), hostname icdfa, user icdfa
Operating System	Kali GNU/Linux Rolling 2025.1 (Debian-based)
Evidence Window	30 September 2026, 17:27 WAT – 01 October 2026
Submission Date	01 October 2026

All testing was carried out on my own authorised lab machine only.

1. EXECUTIVE SUMMARY

I assessed a single Kali Linux lab machine (icdfa) to answer one practical question: if something suspicious happened on this host, would we know about it, and could we prove it afterwards? To find out, I configured kernel auditing with auditd, reviewed the systemd journal for authentication, privilege-use and error events, and ran a Lynis hardening scan. I then mapped what I found to control objectives that a governance team could track over time.

The short answer is: partly. auditd is running and is recording privileged activity, which is good. But the evidence also shows that one of my five audit rules silently failed to load, that 222 error-level log entries have built up over several months without anyone looking at them, and that three failed attempts to run a command as root in July went completely unnoticed. Lynis then scored the host 65/100, below the 70 baseline, and found that the firewall was installed but had no rules. I fixed the firewall during the lab and the score rose to 67. Each of these is a control that looks fine from the outside but does not hold up when you check the evidence.

Priority findings

ID	Finding	Why it matters	Priority
W4-F01	Audit rule set only partly loaded. audit-rules.service failed at 13:00:11 on 01 Oct; 4 of 5 rules are active and the log-integrity watch is missing.	auditd reports "active (running)", so the gap is easy to miss. Tampering with logs would not be audited.	HIGH
W4-F02	No log review is happening. 222 error-level journal entries have accumulated across several months, including kernel soft lockups and RCU stalls.	If errors this obvious go unread, a real security event would be buried in the same way.	HIGH
W4-F03	Failed privilege escalation went undetected. On 17 Jul at 20:57:44, user icdfa made 3 incorrect sudo password attempts to run a command as root.	This is the kind of event an alert should fire on. No auth.log exists and nothing was forwarded or reviewed.	MODERATE
W4-F04	Host hardening below baseline. Lynis hardening index was 65/100 (273 tests). The only formal warning was FIRE-4512: iptables loaded but no rules, so no working firewall. I fixed the firewall during the lab and the index rose to 67. Still open: no GRUB password, no password ageing or hashing rounds, no PAM strength checks.	There was no working host firewall, and the score is still below the 70 baseline. Lynis listed the firewall as present even though it had no rules.	HIGH → partly fixed

Overall control posture: NEEDS IMPROVEMENT. I fixed the firewall during the lab (ufw with default-deny inbound, which raised the Lynis index from 65 to 67). The remaining urgent fixes are to correct the audit rules file so all rules load at boot, to set up a simple log review or alerting routine, and to send authentication events somewhere they will be seen. All three can be done within a week. The remaining Lynis items (boot loader password, password policy) can follow within 30 days.

2. SCOPE, AUTHORISATION AND ENVIRONMENT

The assessment was limited to my own authorised Kali Linux virtual machine. I did not scan, connect to or test any other host, network, cloud account or shared system. The host details below come from `cat /etc/os-release` and the shell prompt.

```
(icdfa@icdfa)-[~]
$ cat /etc/os-release
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2025.1"
VERSION="2025.1"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"
```

Figure 1 – `cat /etc/os-release` on host `icdfa` (Kali GNU/Linux Rolling 2025.1)

Hostname / user	icdfa / icdfa (UID 1000, sudo-capable)
Operating system	Kali GNU/Linux Rolling, VERSION_ID 2025.1, ID_LIKE debian
Platform	Virtual machine (kernel reports <code>vmwgfx</code> and <code>e1000</code> virtual hardware)
Time zone used	WAT (UTC+1), as shown in the system logs
In scope	auditd configuration and events, systemd journal, sudo/PAM activity, Lynis scan
Out of scope	Other hosts, networks, production systems, cloud and third-party services

Where my environment differed from the brief

The brief assumes an Ubuntu-style system. Kali works a little differently, so a few commands had to be swapped for equivalents. The brief allows this as long as it is documented, so here is what I changed and why:

Brief expects	What I found on Kali	What I used instead
<code>/var/log/auth.log</code>	File does not exist. Kali logs to the systemd journal and <code>rsyslog</code> is not installed.	<code>journalctl _COMM=sudo</code> , <code>journalctl _COMM=sshd</code> , <code>journalctl grep -i failed</code>
<code>/var/log/syslog</code>	File does not exist for the same reason.	<code>journalctl -p err</code> and <code>journalctl -p warning</code>
auditd already installed	Not installed ("Unit <code>auditd.service</code> could not be found").	Installed with <code>apt install auditd audispd-plugins</code> , then started and enabled it
SSH activity to review	<code>openssh-server</code> installed but inactive and disabled.	Recorded the empty result as evidence of absence

One side note from my first attempt: I tried the school's browser-based practice VM first, but it runs as a container without `systemd`, so `systemctl` does not work there at all. I moved to my own Kali VM so I could manage `auditd` as a real service.

3. METHODOLOGY

I worked through the lab in four stages. Each stage produced evidence that fed into the next, so the control table in Section 7 is built from real output rather than assumptions.

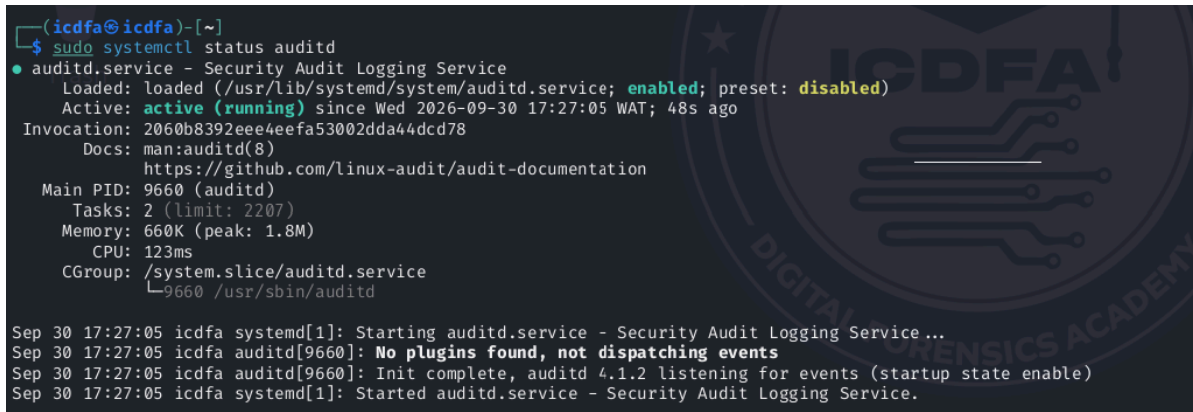
Stage	Tools / sources	What I did	Governance link
1	auditd, auditctl, ausearch, aureport	Installed auditd, wrote custom rules, triggered and queried events, produced summary reports	Accountability, privileged access, file integrity
2	journalctl (journald)	Reviewed SSH, sudo, authentication and error-priority events	Authentication monitoring, log review
3	Lynis	Ran a full system audit and recorded the hardening index, warnings and suggestions	Configuration baseline, vulnerability management
4	Analysis	Mapped findings to control objectives, owners, KPIs and retest criteria; designed SIEM flow	Continuous control monitoring, escalation

4. EVIDENCE BUNDLE 1 – AUDITD CONFIGURATION AND EVENTS

4.1 Service status (Activity 1.1)

auditd was not on the machine when I started. After installing it, I started and enabled the service and checked its state:

```
sudo apt update && sudo apt install -y auditd audispd-plugins
sudo systemctl start auditd && sudo systemctl enable auditd
sudo systemctl status auditd
```

A terminal window showing the command 'sudo systemctl status auditd' and its output. The output indicates that the auditd service is loaded, active (running), and enabled. It also shows the service's invocation details, including its main PID (9660), tasks, memory usage, and CPU usage. Below the status output, there are three log entries from the journal showing the service starting and listening for events.

```
(icdfa@icdfa)-[~]
$ sudo systemctl status auditd
● auditd.service - Security Audit Logging Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; preset: disabled)
   Active: active (running) since Wed 2026-09-30 17:27:05 WAT; 48s ago
 Invocation: 2060b8392eee4eefa53002dda44dcd78
    Docs: man:auditd(8)
          https://github.com/linux-audit/audit-documentation
   Main PID: 9660 (auditd)
     Tasks: 2 (limit: 2207)
    Memory: 660K (peak: 1.8M)
       CPU: 123ms
    CGroup: /system.slice/auditd.service
            └─9660 /usr/sbin/auditd

Sep 30 17:27:05 icdfa systemd[1]: Starting auditd.service - Security Audit Logging Service...
Sep 30 17:27:05 icdfa auditd[9660]: No plugins found, not dispatching events
Sep 30 17:27:05 icdfa auditd[9660]: Init complete, auditd 4.1.2 listening for events (startup state enable)
Sep 30 17:27:05 icdfa systemd[1]: Started auditd.service - Security Audit Logging Service.
```

Figure 2 – auditd active (running), PID 9660, enabled, auditd 4.1.2

What this shows: auditd 4.1.2 has been active since Wed 30 Sep 2026 17:27:05 WAT under PID 9660 and is enabled to start at boot. Note that the vendor preset is "disabled", which means auditd would not have been running on a fresh Kali install unless someone turned it on. The line "No plugins found, not dispatching events" means no audispd plugin is set up, so audit records stay on this machine and are not forwarded anywhere. That is fine for a lab, but on a real server it means a SIEM would never see these events.

4.2 Custom audit rules (Activity 1.2)

I created `/etc/audit/rules.d/custom.rules` with five rules: watches on `/etc/passwd` and `/etc/shadow`, execve logging for 64-bit and 32-bit programs, and a write/attribute watch on `/var/log/auth.log`.

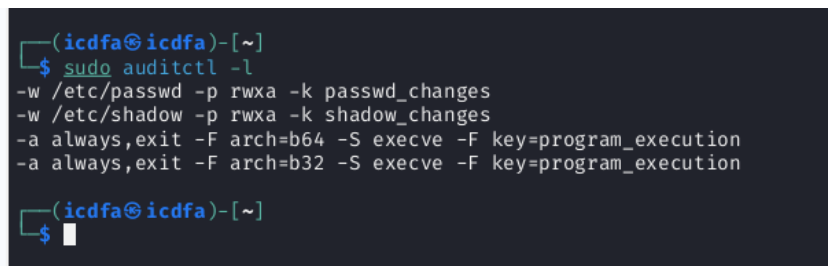


```
icdfa@icdfa: ~  
GNU nano 8.3 /etc/audit/rules.d/custom.rules  
-w /etc/passwd -p rwx -k passwd_changes  
-w /etc/shadow -p rwx -k shadow_changes  
-a always,exit -F arch=b64 -S execve -k program_execution  
-a always,exit -F arch=b32 -S execve -k program_execution  
-w /var/log/auth.log -p wa -k auth_failures  
[ Read 5 lines ]  
[ Help, Write Out, Where Is, Cut, Execute, Location, M-U, M-A, M-B, M-F, Back, Forward, Exit, Read File, Replace, Paste, Justify, Go To Line, M-B, M-F, Next, Forward ]
```

Figure 3 – contents of `/etc/audit/rules.d/custom.rules` in nano

After restarting auditd I listed the rules the kernel had actually loaded:

```
sudo systemctl restart auditd  
sudo auditctl -l
```



```
(icdfa@icdfa)-[~]  
$ sudo auditctl -l  
-w /etc/passwd -p rwx -k passwd_changes  
-w /etc/shadow -p rwx -k shadow_changes  
-a always,exit -F arch=b64 -S execve -F key=program_execution  
-a always,exit -F arch=b32 -S execve -F key=program_execution  
(icdfa@icdfa)-[~]  
$
```

Figure 4 – `auditctl -l` returns only four rules; the `auth.log` watch is missing

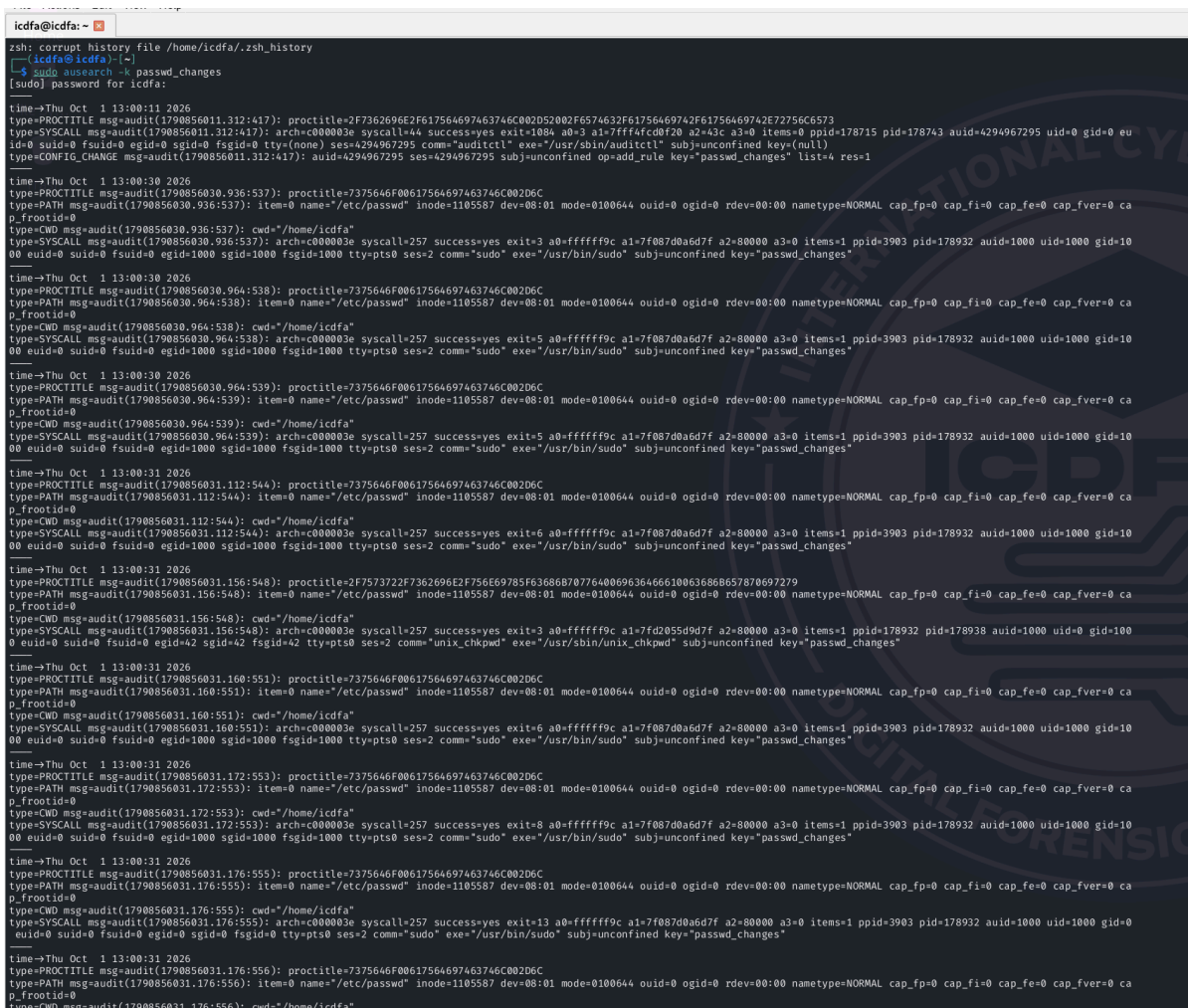
What this shows: only four of the five rules loaded. The `passwd`, `shadow` and both `execve` rules are active, but the `auth.log` watch is not there. Looking back at Figure 3, there are two reasons. First, the last line reads `-pa wa` instead of `-p wa`, which is a syntax error. Second, `/var/log/auth.log` does not exist on Kali, so the watch had nothing to attach to. The journal confirms the failure: at **01 Oct 13:00:11** `systemd` logged "Failed to start `audit-rules.service` – Load Audit Rules" (see Figure 17). I also noticed `-w/etc/shadow` is missing a space; `auditctl` accepted it, but I will tidy it up in the fix.

This is the most useful thing I learned in Module 1. The service status says everything is fine, yet part of the rule set never loaded. Anyone who only checks `systemctl status` would believe log tampering is being audited when it is not. That became finding W4-F01.

4.3 Querying audit events with ausearch (Activity 1.3)

To generate a test event I ran a `sudo` command that touches `/etc/passwd`, then searched by key:

```
sudo ausearch -k passwd_changes
sudo ausearch -k program_execution | tail -20
```



```
icdfa@icdfa:~$ sudo ausearch -k passwd_changes
[sudo] password for icdfa:
time-->Thu Oct 1 13:00:11 2026
type=PROCTITLE msg=audit(1790856011.312:417): proctitle=2F7362696E2F617564697463746C002D5002F6574632F61756469742E72756C6573
type=SYSCALL msg=audit(1790856011.312:417): arch=c000003e syscall=44 success=yes exit=1084 a0=3 a1=7ffff4cd0f20 a2=43c a3=0 items=0 ppid=178715 pid=178743 auid=4294967295 uid=0 gid=0 eu
id=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=4294967295 comm="auditctl" exe="/usr/sbin/auditctl" subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(1790856011.312:417): auid=4294967295 ses=4294967295 subj=unconfined op=add_rule key="passwd_changes" list=4 res=1

time-->Thu Oct 1 13:00:30 2026
type=PROCTITLE msg=audit(1790856030.936:537): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856030.936:537): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856030.936:537): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856030.936:537): arch=c000003e syscall=257 success=yes exit=3 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=10
00 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:30 2026
type=PROCTITLE msg=audit(1790856030.964:538): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856030.964:538): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856030.964:538): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856030.964:538): arch=c000003e syscall=257 success=yes exit=5 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=10
00 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.112:544): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856031.112:544): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.112:544): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856031.112:544): arch=c000003e syscall=257 success=yes exit=6 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=10
00 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.156:548): proctitle=2F7373722F7362696E2F756469785F63686B7077640069636466610063686567870697279
type=PATH msg=audit(1790856031.156:548): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.156:548): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856031.156:548): arch=c000003e syscall=257 success=yes exit=3 a0=ffffff9c a1=7fd2055d9d7f a2=80000 a3=0 items=1 ppid=178932 pid=178938 auid=1000 uid=0 gid=100
0 euid=0 suid=0 fsuid=0 egid=42 sgid=42 fsgid=42 tty=pts0 ses=2 comm="unix_chkpwd" exe="/usr/sbin/unix_chkpwd" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.160:551): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856031.160:551): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.160:551): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856031.160:551): arch=c000003e syscall=257 success=yes exit=6 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=10
00 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.172:553): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856031.172:553): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.172:553): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856031.172:553): arch=c000003e syscall=257 success=yes exit=8 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=10
00 euid=0 suid=0 fsuid=0 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.176:555): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856031.176:555): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.176:555): cwd="/home/icdfa"
type=SYSCALL msg=audit(1790856031.176:555): arch=c000003e syscall=257 success=yes exit=13 a0=ffffff9c a1=7f087d0a6d7f a2=80000 a3=0 items=1 ppid=3903 pid=178932 auid=1000 uid=1000 gid=0
euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="passwd_changes"

time-->Thu Oct 1 13:00:31 2026
type=PROCTITLE msg=audit(1790856031.176:556): proctitle=7375646F00617564697463746C002D6C
type=PATH msg=audit(1790856031.176:556): item=0 name="/etc/passwd" inode=1105587 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 ca
p_frootid=0
type=CWD msg=audit(1790856031.176:556): cwd="/home/icdfa"
```

Figure 5 – ausearch -k passwd_changes showing CONFIG_CHANGE, PATH and SYSCALL records

What this shows:

- **13:00:11** – a CONFIG_CHANGE record shows auditctl adding the passwd_changes rule (op=add_rule, res=1). This is auditd recording changes to its own configuration, which is exactly what you want.
- **13:00:30–13:00:31** – a series of openat (syscall 257) events against /etc/passwd from /usr/bin/sudo. The record shows **auid=1000** (the real logged-in user, icdfa), **uid=1000, euid=0** (running as root), **tty=pts0, ses=2**. So even though the action ran as root, auditd still ties it back to me personally. That is the accountability the control is meant to give.
- **13:00:31** – /usr/sbin/unix_chkpwd also reads /etc/passwd. This is PAM checking my password for sudo.

One practical observation: because the rule uses `-p rwx`, it fires on every read. `sudo` and `PAM` read `/etc/passwd` every time anyone authenticates, so this key fills up with routine noise. For alerting I would narrow it to `-p wa` (writes and attribute changes), which is what an actual account change looks like.

```

[icdfa@icdfa]~$ sudo ausearch -k program_execution | tail -20
type=EXECVE msg=audit(1790876439.396:120360): argc=2 a0="tail" a1="-20"
type=SYSCALL msg=audit(1790876439.396:120360): arch=c000003e syscall=59 success=yes exit=0 a0=7ffd95a14960 a1=7f4429b2ee10 a2=5598e26ebf60 a3=8 items=3 ppid=181395 pid=339043
audit=1000 uid=1000 euid=1000 suid=1000 fsuid=1000 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="tail" exe="/usr/bin/tail" subj=unconfined key="program_execution"

time→Thu Oct 1 18:40:39 2026
type=PROCTITLE msg=audit(1790876439.440:120365): proctitle=2F573722F7362696E2F756E69785F63686870776400696364666100636868657870697279
type=PATH msg=audit(1790876439.440:120365): item=2 name="/lib64/ld-linux-x86-64.so.2" inode=792912 dev=08:01 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790876439.440:120365): item=1 name="/usr/sbin/unix_chkpwd" inode=787023 dev=08:01 mode=0102755 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790876439.440:120365): item=0 name="/usr/sbin/unix_chkpwd" inode=787023 dev=08:01 mode=0102755 ouid=0 ogid=42 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1790876439.440:120365): cwd="/home/icdfa"
type=EXECVE msg=audit(1790876439.440:120365): argc=3 a0="/usr/sbin/unix_chkpwd" a1="icdfa" a2="chkexpiry"
type=SYSCALL msg=audit(1790876439.440:120365): arch=c000003e syscall=59 success=yes exit=0 a0=7fdd3013904a a1=7ffc2e39c580 a2=7fdd3013c018 a3=0 items=3 ppid=339042 pid=339044
audit=1000 uid=0 gid=1000 euid=0 suid=0 fsuid=0 egid=42 sgid=42 fsgid=42 tty=pts0 ses=2 comm="unix_chkpwd" exe="/usr/sbin/unix_chkpwd" subj=unconfined key="program_execution"

time→Thu Oct 1 18:40:39 2026
type=PROCTITLE msg=audit(1790876439.460:120378): proctitle=61757365617263680020680070726F6772616D5F657865637574696F6E
type=PATH msg=audit(1790876439.460:120378): item=2 name="/lib64/ld-linux-x86-64.so.2" inode=792912 dev=08:01 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790876439.460:120378): item=1 name="/usr/sbin/ausearch" inode=864440 dev=08:01 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(1790876439.460:120378): item=0 name="/usr/sbin/ausearch" inode=864440 dev=08:01 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_p_i=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1790876439.460:120378): cwd="/home/icdfa"
type=EXECVE msg=audit(1790876439.460:120378): argc=3 a0="ausearch" a1="-k" a2="program_execution"
type=SYSCALL msg=audit(1790876439.460:120378): arch=c000003e syscall=59 success=yes exit=0 a0=564b7beb5e40 a1=564b7beb8090 a2=564b7beb8090 a3=0 items=3 ppid=339045 pid=339046
audit=1000 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts2 ses=2 comm="ausearch" exe="/usr/sbin/ausearch" subj=unconfined key="program_execution"

[icdfa@icdfa]~$

```

Figure 6 – `ausearch -k program_execution | tail -20` (EXECVE and SYSCALL records, 01 Oct 18:40:39)

What this shows: the `execve` rule is recording every program that runs, with its arguments. At 18:40:39 on 01 Oct it captured `tail -20` (`audit=1000, uid=1000, tty=pts0`), `/usr/sbin/unix_chkpwd icdfa chkexpiry` running as root with `egid=42` (the shadow group, which is how `PAM` reads password-expiry data), and `ausearch -k program_execution` itself (`audit=1000, euid=0, tty=pts2`). In other words, `auditd` recorded me investigating `auditd`. That is how it should work, because the person checking the logs is also accountable. It also shows how fast this key fills up: three records in the same second just from one search command.

4.4 Audit summary reports with `aureport` (Activity 1.4)

```

sudo aureport
sudo aureport --failed
sudo aureport --login

```

```

[icdfa@icdfa]~$ sudo aureport
Summary Report
Range of time in logs: 01/10/2026 15:27:35.800 - 01/10/2026 16:32:43.512
Selected time for report: 01/10/2026 15:27:35 - 01/10/2026 16:32:43.512
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 1
Number of failed authentications: 0
Number of users: 3
Number of terminals: 7
Number of host names: 2
Number of executables: 54
Number of commands: 75
Number of files: 87
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 22
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 3
Number of process IDs: 22533
Number of events: 22964

```

Figure 7 – `aureport` summary

```
(icdfa@icdfa)-[~]
$ sudo aureport --failed

Failed Summary Report
=====
Range of time in logs: 01/10/2026 15:27:35.800 - 01/10/2026 16:39:48.940
Selected time for report: 01/10/2026 15:27:35 - 01/10/2026 16:39:48.940
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 2
Number of terminals: 2
Number of host names: 0
Number of executables: 2
Number of commands: 2
Number of files: 22
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 122
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 1
Number of process IDs: 21
Number of events: 122

(icdfa@icdfa)-[~]
$
```

Figure 8 – aureport --failed

```
(icdfa@icdfa)-[~]
$ sudo aureport --login

Login Report
=====
# date time auid host term exe success event
=====
<no events of interest were found>

(icdfa@icdfa)-[~]
$
```

Figure 9 – aureport --login: no events of interest

What this shows: in about an hour (15:27:35 to 16:32:43 on 01 Oct) auditd recorded **22,964 events**, 75 distinct commands, 54 executables, 1 authentication, 3 users and 3 active rule keys. The failed report shows **122 failed syscalls** and no failed logins or failed authentications in that window. The login report is empty because my desktop session started before auditd was installed.

Two things stand out. First, 22,964 events an hour from one quiet lab machine is a lot. Almost all of it comes from the execve rules logging every program that runs. On a busy server that volume would fill disks and drown a SIEM, so the rule should be filtered to real users (for example `-F auid>=1000 -F auid!=unset`). Second, the report window starts at 15:27, which is later than the 13:00 events in Figure 5. That suggests the audit log has already rotated because of the volume, so older events are no longer in the active file. I would confirm this with `sudo ls -la /var/log/audit/` and review `max_log_file` and `num_logs` in `/etc/audit/auditd.conf`, because rotated-away evidence is lost evidence.

4.5 Interpretation for governance

Finding ID	W4-F01
------------	--------

Evidence source	systemctl status auditd; auditctl -l; journalctl -p err; ausearch; aureport
What I observed	auditd is active and enabled, but audit-rules.service failed at 01 Oct 13:00:11. Only 4 of 5 rules loaded. The auth.log watch failed because of a typo (-pa) and because the file does not exist on Kali. The remaining rules are working: sudo access to /etc/passwd was recorded with uid=1000, euid=0, tty=pts0.
Who / when	icdfa (uid 1000), session 2, pts0, 01 Oct 2026 13:00:11–13:00:31 WAT
Security significance	A rule that fails silently gives false assurance. There is no audit trail if someone deletes or edits logs, and the failure is not visible from the service status.
Governance action	Fix and re-load the rules file, add a log-directory watch suited to journald, alert whenever audit-rules.service fails, and check the loaded rule count after every reboot.

5. EVIDENCE BUNDLE 2 – LINUX LOG ANALYSIS

5.1 System journal review (Activity 2.1)

```
sudo journalctl --since "today"
sudo journalctl -u ssh
sudo journalctl -p err
```

```

(icdfa@icdfa)-[~]
$ sudo journalctl --since "today"
Oct 01 08:59:35 icdfa systemd[1]: Starting apt-daily-upgrade.service - Daily apt upgrade and clean activities...
Oct 01 08:59:35 icdfa systemd[1]: Starting apt-daily-upgrade.service - Daily apt upgrade and clean activities...
Oct 01 08:59:37 icdfa systemd[1]: Starting dpkg-db-backup.service - Daily dpkg database backup service...
Oct 01 08:59:37 icdfa systemd[1]: Starting phpsessionclean.service - Clean php session files...
Oct 01 08:59:37 icdfa systemd[1]: Starting chkrootkit.service - chkrootkit...
Oct 01 08:59:37 icdfa systemd[1]: Starting apt-daily-upgrade.service - Daily apt upgrade and clean activities...
Oct 01 08:59:37 icdfa systemd[1]: Starting dpkg-db-backup.service - Daily dpkg database backup service...
Oct 01 08:59:37 icdfa systemd[1]: Starting phpsessionclean.service - Clean php session files...
Oct 01 08:59:37 icdfa systemd[1]: Starting chkrootkit.service - chkrootkit...
Oct 01 08:59:38 icdfa systemd[1]: Starting exim4-base.service - exim4-base housekeeping...
Oct 01 08:59:38 icdfa systemd[1]: Started lynis.service - Security audit and vulnerability scanner.
Oct 01 08:59:38 icdfa systemd[1]: Starting man-db.service - Daily man-db regeneration...
Oct 01 08:59:40 icdfa NetworkManager[1399]: <info> [1790841580.2174] device (eth0): state change: activated → unavailable (reason 'carrier-changed', managed-type: 'full')
Oct 01 08:59:40 icdfa NetworkManager[1399]: <info> [1790841580.2176] dhcpv4 (eth0): canceled DHCP transaction
Oct 01 08:59:40 icdfa NetworkManager[1399]: <info> [1790841580.2176] dhcpv4 (eth0): activation: beginning transaction (timeout in 45 seconds)
Oct 01 08:59:40 icdfa NetworkManager[1399]: <info> [1790841580.2176] dhcpv4 (eth0): state changed no lease
Oct 01 08:59:40 icdfa systemd[1]: phpsessionclean.service: Deactivated successfully.
Oct 01 08:59:40 icdfa systemd[1]: Finished phpsessionclean.service - Clean php session files.
Oct 01 08:59:45 icdfa kernel: e1000: eth0 NIC Link is Up 1000 Mbps Full Duplex, Flow Control: None
Oct 01 08:59:45 icdfa NetworkManager[1399]: <info> [1790841585.5539] manager: NetworkManager state is now DISCONNECTED
Oct 01 08:59:45 icdfa NetworkManager[1399]: <info> [1790841585.5763] device (eth0): carrier: link connected
Oct 01 08:59:45 icdfa dbus-daemon[1327]: [system] Activating via systemd: service name='org.freedesktop.nm_dispatcher' unit='dbus-org.freedesktop.nm_dispatcher.service' requested by ':1.5' (uid=0 pid=1399 comm=)
Oct 01 08:59:45 icdfa NetworkManager[1399]: <info> [1790841585.6080] device (eth0): state change: unavailable → disconnected (reason 'carrier-changed', managed-type: 'full')
Oct 01 08:59:45 icdfa systemd[1]: Starting NetworkManager-dispatcher.service - Network Manager Script Dispatcher Service...
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.2744] policy: auto-activating connection 'Auto Ethernet' (addd5e3-345c-4c9b-95c4-2bb1801e2dd1)
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.2789] device (eth0): Activation: starting connection 'Auto Ethernet' (addd5e3-345c-4c9b-95c4-2bb1801e2dd1)
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.2792] manager: NetworkManager state is now CONNECTING
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.2795] device (eth0): state change: prepare → config (reason 'none', managed-type: 'full')
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.3072] device (eth0): state change: config → ip-config (reason 'none', managed-type: 'full')
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.3304] dhcpv4 (eth0): activation: beginning transaction (timeout in 45 seconds)
Oct 01 08:59:46 icdfa dbus-daemon[1327]: [system] Successfully activated service 'org.freedesktop.nm_dispatcher'
Oct 01 08:59:46 icdfa systemd[1]: Started NetworkManager-dispatcher.service - Network Manager Script Dispatcher Service.
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.7783] dhcpv4 (eth0): state changed new lease, address:192.168.137.129, acd pending
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.9491] dhcpv4 (eth0): state changed new lease, address:192.168.137.129
Oct 01 08:59:46 icdfa NetworkManager[1399]: <info> [1790841586.9498] policy: set 'Auto Ethernet' (eth0) as default for IPv4 routing and DNS
Oct 01 08:59:52 icdfa kernel: e1000: eth0 NIC Link is Up 1000 Mbps Full Duplex, Flow Control: None
Oct 01 08:59:54 icdfa NetworkManager[1399]: <info> [1790841594.5833] device (eth0): state change: ip-config → ip-check (reason 'none', managed-type: 'full')
Oct 01 08:59:59 icdfa kernel: e1000: eth0 NIC Link is Up 1000 Mbps Full Duplex, Flow Control: None
Oct 01 09:00:07 icdfa rtkit-daemon[2498]: The canary thread is apparently starving. Taking action.
Oct 01 09:00:16 icdfa kernel: e1000: eth0 NIC Link is Down
Oct 01 09:00:07 icdfa rtkit-daemon[2498]: Demoting known real-time threads.
Oct 01 09:00:13 icdfa NetworkManager[1399]: <info> [1790841613.3039] device (eth0): carrier: link connected
Oct 01 09:00:17 icdfa rtkit-daemon[2498]: Successfully demoted thread 2715 of process 2696.

```

Figure 10 – journalctl --since "today" (first screen, 01 Oct 2026)

Today's journal is mostly normal housekeeping: apt-daily-upgrade, dpkg backups, NetworkManager getting a DHCP lease (192.168.137.129 on eth0) and the network link going up and down a few times. Interestingly, at 08:59:38 systemd also started lynis.service, so Lynis is already installed with a scheduled run on this machine. Nobody appears to be reading its output, though, which ties into W4-F02.

```

(icdfa@icdfa)-[~]
$ sudo journalctl -u ssh
[sudo] password for icdfa:
-- No entries --

```

Figure 11 – journalctl -u ssh: no entries

```
(icdfa@icdfa)-[~]
$ sudo journalctl _COMM=sshd 2>/dev/null | head -20
[sudo] password for icdfa:
-- No entries --

(icdfa@icdfa)-[~]
$
```

Figure 12 – journalctl _COMM=sshd: no entries

SSH: both queries return "-- No entries --". `systemctl status ssh` shows the OpenSSH server is installed but inactive and disabled, so there has never been an SSH session to log. That reduces the attack surface on this host. The governance point is that the disabled state should be written into the configuration baseline, so that if SSH is ever switched on without approval it shows up as drift. On a production server where SSH is expected, an empty `sshd` log would be a red flag in its own right, because it could mean the logs were cleared.

```
(icdfa@icdfa)-[~]
$ sudo systemctl status ssh
o ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
   Active: inactive (dead)
     Docs: man:sshd(8)
           man:sshd_config(5)

(icdfa@icdfa)-[~]
$
```

Figure 13 – systemctl status ssh: loaded, disabled, preset disabled, inactive (dead)

5.2 Authentication and privilege-use analysis (Activity 2.2)

The brief's commands `grep -i "failed password" /var/log/auth.log` and `grep -i "sudo" /var/log/auth.log` returned "No such file or directory", because Kali does not create `auth.log`. I used the journal instead:

```
# Kali equivalent of grep "failed password" /var/log/auth.log
sudo journalctl | grep -i "failed"

# Kali equivalent of grep "sudo" /var/log/auth.log
sudo journalctl _COMM=sudo | tail -20

# General authentication events
sudo journalctl | grep -i "authentication" | tail -20
```

```
(icdfa@icdfa)-[~]
$ sudo journalctl _COMM=sudo | tail -20
[sudo] password for icdfa:
Oct 01 17:29:05 icdfa sudo[303605]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/systemctl ssh status
Oct 01 17:29:05 icdfa sudo[303605]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 17:29:05 icdfa sudo[303605]: pam_unix(sudo:session): session closed for user root
Oct 01 17:29:26 icdfa sudo[303788]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/systemctl status ssh
Oct 01 17:29:26 icdfa sudo[303788]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 17:29:26 icdfa sudo[303788]: pam_unix(sudo:session): session closed for user root
Oct 01 17:37:04 icdfa sudo[307473]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl -p err
Oct 01 17:37:04 icdfa sudo[307473]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 17:37:04 icdfa sudo[307473]: pam_unix(sudo:session): session closed for user root
Oct 01 17:37:22 icdfa sudo[307647]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl -p err
Oct 01 17:37:22 icdfa sudo[307647]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 17:37:22 icdfa sudo[307647]: pam_unix(sudo:session): session closed for user root
Oct 01 17:40:25 icdfa sudo[309242]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl -p err
Oct 01 17:40:26 icdfa sudo[309242]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 17:40:26 icdfa sudo[309242]: pam_unix(sudo:session): session closed for user root
Oct 01 18:10:23 icdfa sudo[324071]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl _COMM=ssh
Oct 01 18:10:23 icdfa sudo[324071]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)
Oct 01 18:10:23 icdfa sudo[324071]: pam_unix(sudo:session): session closed for user root
Oct 01 18:38:34 icdfa sudo[337834]: icdfa : TTY=pts/0 ; PWD=/home/icdfa ; USER=root ; COMMAND=/usr/bin/journalctl _COMM=sudo
Oct 01 18:38:34 icdfa sudo[337834]: pam_unix(sudo:session): session opened for user root(uid=0) by icdfa(uid=1000)

(icdfa@icdfa)-[~]
$
```

Figure 14 – journalctl _COMM=sudo | tail -20 (all sudo use on 01 Oct, 17:29–18:38)

Sudo use: every sudo event in this window came from icdfa on pts/0, working in /home/icdfa, running as USER=root. Each one leaves three lines: the command itself (for example COMMAND=/usr/bin/journalctl -p err), then pam_unix "session opened for user root(uid=0) by icdfa(uid=1000)", then "session closed". All of these commands were my own assessment steps (checking SSH status, reading error logs, searching for sshd and sudo events), and there were no failed attempts in this window. This is a good result: the journal keeps a clear record of who ran what as root and when, which is what a privileged-access control needs. The gap is that nobody else sees it, because none of it is forwarded or alerted on.

```
(icdfa@icdfa)-[~]
$ sudo journalctl | grep -i "authentication" | tail -20
Sep 29 16:23:42 icdfa lynis[385192]: - LDAP authentication support [ NOT ENABLED ]
Sep 29 16:52:41 icdfa lynis[385192]: * Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
Sep 29 16:52:43 icdfa lynis[385192]: * Article: Linux password security: hashing rounds: https://linux-audit.com/authentication/configure-the-minimum-password-length-on-linux-systems/
Sep 30 09:47:57 icdfa lynis[581972]: - Authentication:
Sep 30 09:47:58 icdfa lynis[581972]: - PAM (Pluggable Authentication Modules):
Sep 30 09:53:46 icdfa lynis[581972]: [-] Users, Groups and Authentication
Sep 30 09:53:54 icdfa lynis[581972]: - NIS+ authentication support [ NOT ENABLED ]
Sep 30 09:53:55 icdfa lynis[581972]: - NIS authentication support [ NOT ENABLED ]
Sep 30 09:54:19 icdfa lynis[581972]: - Checking Linux single user mode authentication [ OK ]
Sep 30 09:54:24 icdfa lynis[581972]: - LDAP authentication support [ NOT ENABLED ]
Sep 30 17:14:28 icdfa polkitd[1334]: Registered Authentication Agent for unix-session:2 (system bus name :1.43 [/usr/libexec/polkit-mate-authentication-agent-1], object path /org/mate/PolicyKit1/AuthenticationAgent, locale en_NG)
Oct 01 09:52:08 icdfa lynis[21690]: - Authentication:
Oct 01 09:52:08 icdfa lynis[21690]: - PAM (Pluggable Authentication Modules):
Oct 01 09:53:08 icdfa lynis[21690]: [-] Users, Groups and Authentication
Oct 01 09:55:10 icdfa lynis[21690]: - NIS+ authentication support [ NOT ENABLED ]
Oct 01 09:55:10 icdfa lynis[21690]: - NIS authentication support [ NOT ENABLED ]
Oct 01 09:55:15 icdfa lynis[21690]: - Checking Linux single user mode authentication [ OK ]
Oct 01 09:55:16 icdfa lynis[21690]: - LDAP authentication support [ NOT ENABLED ]
Oct 01 10:25:16 icdfa lynis[21690]: * Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]
Oct 01 10:25:17 icdfa lynis[21690]: * Article: Linux password security: hashing rounds: https://linux-audit.com/authentication/configure-the-minimum-password-length-on-linux-systems/

(icdfa@icdfa)-[~]
$
```

Figure 15 – journalctl | grep -i "authentication" | tail -20

Authentication events: there are no failed logins here. Almost every line comes from Lynis, which turns out to run on a schedule: there are runs on 29 Sep (16:23–16:52), 30 Sep (09:47–09:54) and 01 Oct (09:52–10:25). Each time, Lynis checked PAM and single-user mode authentication and, on 29 Sep and 01 Oct, recommended "Install fail2ban to automatically ban hosts that commit multiple authentication errors [DEB-0880]". The only other entry is polkitd registering the MATE authentication agent for my desktop session at 17:14:28 on 30 Sep. So a hardening scanner has been giving the same advice every day, and no one has acted on it. That supports W4-F02: the tools are producing evidence, but no process exists to review it.

What I found: there were no SSH or remote login failures, which matches SSH being disabled. However, the error-priority log (Figure 17) contains this line:

```
Jul 17 20:57:44 icdfa sudo[73686]: icdfa : 3 incorrect password attempts ;  
TTY=pts/1 ; PWD=/home/icdfa/GRC101_Lab/03_GRC_Evidence_Folder ; USER=root ;  
COMMAND=...
```

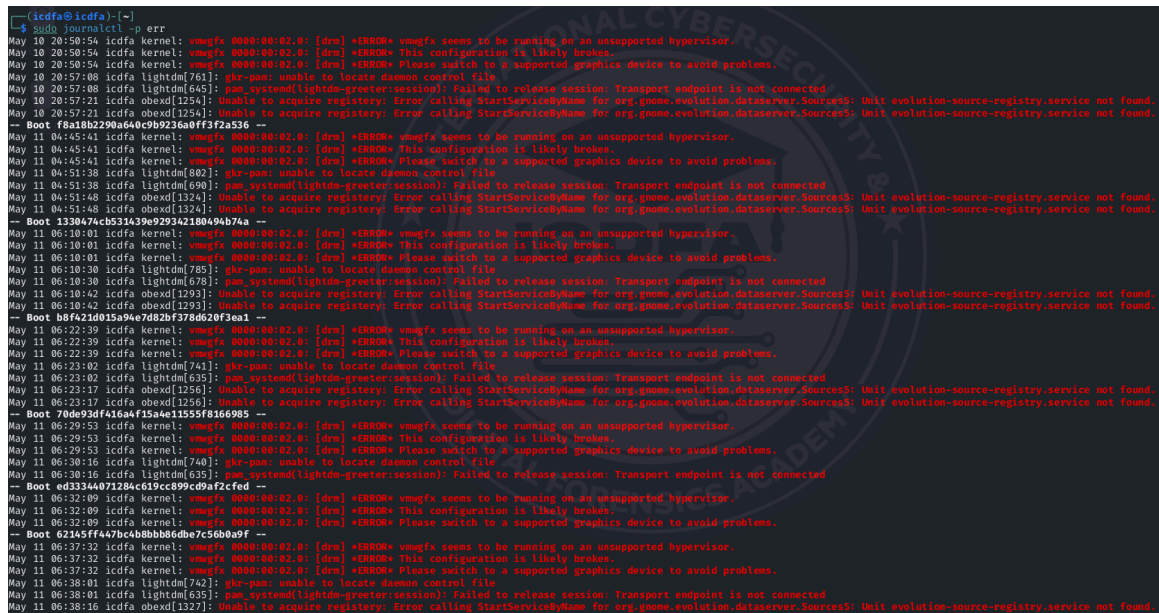
Someone at the icdfa account tried three times to run a command as root and got the password wrong each time. In this case it was almost certainly me during the GRC101 lab, given the working directory. But the system had no way of knowing that. Nothing alerted on it, it was never reviewed, and it only surfaced today because I happened to look. On a shared or production server, repeated failed sudo attempts are a classic sign of someone testing a stolen or guessed account, so this is finding W4-F03.

Not having auth.log is a governance issue on its own. The journal does hold the data, but the brief, most runbooks and many SIEM collectors expect a flat auth.log. Either rsyslog should be installed so auth.log exists, or the collector should be set up to read journald directly. Either way, the decision should be written down.

5.3 System error and warning review (Activity 2.3)

Because /var/log/syslog does not exist on Kali, I reviewed error-priority journal entries and then summarised them by source:

```
sudo journalctl -p err | wc -l  
sudo journalctl -p err | head -20  
sudo journalctl -p err | awk '{print $5}' | sort | uniq -c | sort -rn | head -15
```



```
(icdfa@icdfa)-[~]  
$ sudo journalctl -p err  
May 10 20:58:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 10 20:58:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 10 20:58:54 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 10 20:57:08 icdfa lightdm[761]: gdm-pam: unable to locate daemon control file  
May 10 20:57:08 icdfa lightdm[646]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
-- Boot f8a18b2290a640c9b923a6aff3f2a536 --  
May 11 04:45:44 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 04:45:44 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 04:45:44 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 11 04:51:38 icdfa lightdm[802]: gdm-pam: unable to locate daemon control file  
May 11 04:51:38 icdfa lightdm[690]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
-- Boot 133b474cb531a39e9293a2180494b7aa --  
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 11 06:10:30 icdfa lightdm[785]: gdm-pam: unable to locate daemon control file  
May 11 06:10:30 icdfa lightdm[678]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
May 11 06:10:42 icdfa obexd[1293]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
May 11 06:10:42 icdfa obexd[1293]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
-- Boot b8fa21d015a94e7d82bf378d620f3ea1 --  
May 11 06:22:39 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 06:22:39 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 06:22:39 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 11 06:23:02 icdfa lightdm[741]: gdm-pam: unable to locate daemon control file  
May 11 06:23:02 icdfa lightdm[635]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
May 11 06:23:17 icdfa obexd[1256]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
May 11 06:23:17 icdfa obexd[1256]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.  
-- Boot 70de93df416af15a4e1155f8166985 --  
May 11 06:29:53 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 06:29:53 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 06:29:53 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 11 06:30:16 icdfa lightdm[740]: gdm-pam: unable to locate daemon control file  
May 11 06:30:16 icdfa lightdm[635]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
-- Boot e63334407128cc919cc899cd9af2cfed --  
May 11 06:32:09 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 06:32:09 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 06:32:09 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
-- Boot 621a5ff447bc4ab8bb86db07c56b0a9f --  
May 11 06:37:32 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.  
May 11 06:37:32 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configuration is likely broken.  
May 11 06:37:32 icdfa kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.  
May 11 06:38:01 icdfa lightdm[742]: gdm-pam: unable to locate daemon control file  
May 11 06:38:01 icdfa lightdm[635]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected  
May 11 06:38:16 icdfa obexd[1327]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
```

Figure 16 – journalctl -p err (start of output)

```

icdfa@icdfa: ~
Apr 01 07:46:49 icdfa kernel: rcu: INFO: rcu_preempt self-detected stall on CPU
Apr 01 07:46:50 icdfa kernel: rcu: 0->...! (1 ticks this GP) ider=a83c/1/0-4000000000000000 softirq=16104851/7614805) fq=0
Apr 01 08:20:34 icdfa kernel: rcu: (t=7695 jiffies g=13902401 q=61 ncpu=1)
Apr 01 08:20:34 icdfa kernel: rcu: rcu_preempt kthread timer wakeup didn't happen for 7695 jiffies! g13902401 f=0x0 RCU_GP_WAIT_FQS(5) ->state=0x402
Apr 01 08:20:34 icdfa kernel: rcu: Possible timer handling issue on smp0s timer: softirq=16104851/7614805)
Apr 01 08:20:34 icdfa kernel: rcu: rcu_preempt kthread starved for 7695 jiffies! g13902401 f=0x0 RCU_GP_WAIT_FQS(5) ->state=0x402 ->cpu=0
Apr 01 08:20:34 icdfa kernel: rcu: Unless rcu_preempt kthread gets sufficient CPU time, OOM is now expected behavior.
Apr 01 08:20:34 icdfa kernel: rcu: RCU grace-period kthread stack dump:
Apr 01 08:43:43 icdfa kernel: watchdog: BUG: soft lockup - CPU#0 stuck for 35s! [bashname:1951054]
Apr 01 10:39:50 icdfa kernel: #1000 0000:02:01:0 etob: Reset adapter
Apr 01 19:15:02 icdfa systemd[1]: system-udev.service: Watchdog timeout (limit 3min):
Apr 01 19:15:23 icdfa systemd-udevd[3456533]: /etc/udev/rules.d/99-vmmware-scsi-udev.rules:8 Invalid value "/bin/sh -c 'echo 100 >/sys/udev/timeout'" for RUN (char 27: invalid substitution type), ignoring
Apr 02 08:47:21 icdfa kernel: rcu: INFO: rcu_preempt detected stall on CPU#0 (smp0s)
Apr 02 08:47:21 icdfa kernel: rcu: (Detected by 0, t=9439 jiffies, g=32702869, q=20 ncpu=1)
Apr 02 09:29:18 icdfa kernel: rcu: All QoSs seem, last rcu_preempt kthread activity 9439 (4338627189-4338617670), jiffies_till_next_fqs=1, root ->qsmask=0x0
Apr 02 09:29:18 icdfa kernel: rcu: rcu_preempt kthread starved for 9439 jiffies! g32702869 f=0x0 RCU_GP_WAIT_FQS(5) ->state=0x0 ->cpu=0
Apr 02 09:29:18 icdfa kernel: rcu: Unless rcu_preempt kthread gets sufficient CPU time, OOM is now expected behavior.
Apr 02 09:29:18 icdfa kernel: rcu: RCU grace-period kthread stack dump:
Apr 02 09:29:23 icdfa kernel: rcu: Stack dump where RCU GP kthread last ran:
-- Boot 442001fecb242ba3b0c20b0cf5b43f --
Apr 22 21:57:47 icdfa kernel: p11a: smbus 0000:00:07:3: SMBus Host Controller not enabled!
Apr 22 21:57:47 icdfa systemd-udevd[493]: /etc/udev/rules.d/99-vmmware-scsi-udev.rules:8 Invalid value "/bin/sh -c 'echo 100 >/sys/udev/timeout'" for RUN (char 27: invalid substitution type), ignoring
Apr 22 21:59:33 icdfa lightdm[3248]: gkr-pam: unable to locate daemon control file
Apr 22 21:59:33 icdfa lightdm[2493]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
Apr 22 22:00:14 icdfa obexd[4132]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Apr 22 22:00:14 icdfa obexd[4132]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot febfaaf989654839baec2c195729051 --
Apr 22 22:00:14 icdfa kernel: p11a: smbus 0000:00:07:3: SMBus Host Controller not enabled!
Apr 22 22:00:14 icdfa systemd-udevd[493]: /etc/udev/rules.d/99-vmmware-scsi-udev.rules:8 Invalid value "/bin/sh -c 'echo 100 >/sys/udev/timeout'" for RUN (char 27: invalid substitution type), ignoring
Apr 22 22:07:52 icdfa lightdm[2613]: gkr-pam: unable to locate daemon control file
Apr 22 22:07:53 icdfa lightdm[2670]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
Apr 22 22:08:34 icdfa obexd[3331]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Apr 22 22:08:34 icdfa obexd[3331]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot b872da63cae9f9e94df0ea02e0e41cb --
Jul 17 20:54:04 icdfa kernel: p11a: smbus 0000:00:07:3: SMBus Host Controller not enabled!
Jul 17 20:54:04 icdfa systemd-udevd[494]: /etc/udev/rules.d/99-vmmware-scsi-udev.rules:8 Invalid value "/bin/sh -c 'echo 100 >/sys/udev/timeout'" for RUN (char 27: invalid substitution type), ignoring
Jul 17 20:55:55 icdfa lightdm[3339]: gkr-pam: unable to locate daemon control file
Jul 17 20:55:55 icdfa lightdm[2572]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
Jul 17 20:56:31 icdfa obexd[4059]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Jul 17 20:56:31 icdfa obexd[4059]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Jul 17 23:17:44 icdfa sudo[73586]: icdfa : 3 incorrect password attempts : TTY=pts/1; PWD=/home/icdfa/gdrc801_lab/03_GRC_Evidence_Folder ; USER=root ; COMMAND=
Sep 29 16:13:22 icdfa systemctl[436192]: Failed to list unit files: Connection timed out
Sep 29 16:49:41 icdfa systemctl[629773]: Failed to list unit files: Connection timed out
-- Boot 559d04d658de470d90a77c1c2c7ce64 --
Sep 30 17:12:43 icdfa kernel: p11a: smbus 0000:00:07:3: SMBus Host Controller not enabled!
Sep 30 17:12:43 icdfa systemd-udevd[497]: /etc/udev/rules.d/99-vmmware-scsi-udev.rules:8 Invalid value "/bin/sh -c 'echo 100 >/sys/udev/timeout'" for RUN (char 27: invalid substitution type), ignoring
Sep 30 17:14:06 icdfa lightdm[2662]: gkr-pam: unable to locate daemon control file
Sep 30 17:14:06 icdfa lightdm[2493]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
Sep 30 17:14:59 icdfa obexd[3341]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Sep 30 17:14:59 icdfa obexd[3341]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
Oct 01 09:15:26 icdfa kernel: watchdog: BUG: soft lockup - CPU#0 stuck for 24s! [homerker/0:1:27567]
Oct 01 13:40:11 icdfa systemd[1]: Failed to start audit-rules.service - Load Audit Rules.
[lines 171-222/222 (END)]

```

Figure 17 – journalctl -p err (end of output, lines 171–222 of 222)

```

$ sudo journalctl -p err | wc -l
22
--(icdfa@icdfa)-[~]
$ sudo journalctl -p err | head -20
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* This configuration is likely broken.
May 10 20:50:54 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 10 20:57:08 icdfa lightdm[761]: gkr-pam: unable to locate daemon control file
May 10 20:57:08 icdfa lightdm[645]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
May 10 20:57:21 icdfa obexd[1254]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot f8a18b2290a640c9b9236a0ff3f2a536 --
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* This configuration is likely broken.
May 11 04:45:41 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 11 04:51:38 icdfa lightdm[802]: gkr-pam: unable to locate daemon control file
May 11 04:51:38 icdfa lightdm[690]: pam_system(lightdm-greeter:session): Failed to release session: Transport endpoint is not connected
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
May 11 04:51:48 icdfa obexd[1324]: Unable to acquire registry: Error calling StartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution-source-registry.service not found.
-- Boot 1330474cb531439e929342180494b74a --
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* vmwgfx seems to be running on an unsupported hypervisor.
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* This configuration is likely broken.
May 11 06:10:01 icdfa kernel: vmwgfx 0000:00:02:0: [drm] *ERROR* Please switch to a supported graphics device to avoid problems.
May 11 06:10:30 icdfa lightdm[785]: gkr-pam: unable to locate daemon control file
--(icdfa@icdfa)-[~]
$

```

Figure 18 – error count (222) and first 20 entries

```

--(icdfa@icdfa)-[~]
$ sudo journalctl -p err | awk '{print $5}' | sort | uniq -c | sort -rn | head -15
104 kernel:
21
3 systemd-udevd[494]:
3 lightdm[635]:
2 systemd-udevd[493]:
2 systemd[1]:
2 obexd[4132]:
2 obexd[4059]:
2 obexd[3341]:
2 obexd[3331]:
2 obexd[3205]:
2 obexd[1999]:
2 obexd[1960]:
2 obexd[1952]:
2 obexd[1944]:
--(icdfa@icdfa)-[~]
$

```

Figure 19 – error sources ranked by count

What this shows: there are **222 error-level entries** spread across many boots between April and October 2026. Grouped by source:

Source	Count	What the messages say	My assessment
kernel	104	vmwgfx "unsupported hypervisor... configuration is likely broken"; RCU stalls; "watchdog: BUG: soft lockup – CPU#0 stuck for 35s" (Apr 01) and "stuck for 24s" (Oct 01 09:15:26); e1000 adapter reset	The graphics errors are VM noise. The soft lockups and RCU stalls are more serious: the CPU stopped responding for up to 35 seconds. On a real server that means outages, missed events, or a host that is overloaded.
obexd	2 per boot	Unable to acquire registry: evolution-source-registry.service not found	Bluetooth file-transfer daemon trying to use a service that is not installed. An unneeded service that should be disabled.
systemd-udev	5	Invalid value in /etc/udev/rules.d/99-vmware-scsi-udev.rules line 8	A broken VMware udev rule, repeated at every boot.
lightdm / PAM	3+	gkr-pam: unable to locate daemon control file; pam_systemd: Failed to release session	PAM is part of the authentication stack. Low risk, but it should be checked and fixed, not ignored.
sudo	1	3 incorrect password attempts, USER=root (17 Jul 20:57:44)	Failed privilege escalation. See W4-F03.
systemd	2+	Failed to start audit-rules.service (01 Oct 13:00:11); systemctl "Failed to list unit files: Connection timed out" (29–30 Sep)	Audit rules failed to load. See W4-F01.

Most of these entries are not attacks. What matters is that the same errors repeat at every boot for months, and nobody has acted on them. Real security events are mixed in with them: the failed sudo attempts, the audit rules failing to load. When nobody reads the log, the important lines get lost among the routine ones. That is finding W4-F02.

I also noticed that the journal is not in strict date order: April entries appear after May entries in the same output. That usually means the clock changed between boots (common with VMs that are suspended and resumed) or the journal files were rotated. It matters because SIEM correlation depends on accurate timestamps, so time synchronisation should be checked with `timedatectl`.

5.4 Security event summary

Event / condition	Evidence source	Time (WAT)	User / service	Security significance	Recommended action
Audit rules failed to load	journalctl -p err; auditctl -l	01 Oct 13:00:11	systemd / audit-rules.service	Log-integrity watch missing while auditd looks healthy	Fix rules file; alert on audit-rules.service failure
3 failed sudo attempts to root	journalctl -p err	17 Jul 20:57:44	icdfa (pts/1)	Possible privilege-escalation attempt; nothing alerted	Alert on ≥ 3 sudo failures; forward auth events to SIEM
Privileged read of /etc/passwd	ausearch -k passwd_changes	01 Oct 13:00:30	icdfa audit=1000, euid=0	Shows auditd ties root actions to the real user	Keep; narrow rule to -p wa to cut noise

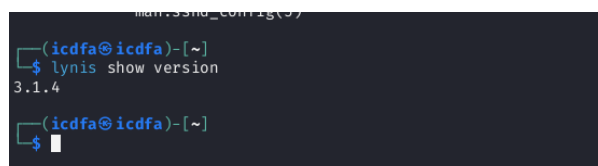
Event / condition	Evidence source	Time (WAT)	User / service	Security significance	Recommended action
Kernel soft lockup / RCU stall	journalctl -p err	01 Apr; 01 Oct 09:15:26	kernel	Host stops responding; events and logging may be lost	Review VM resources; monitor for repeats
222 errors never reviewed	journalctl -p err wc -l	Apr – Oct 2026	kernel, obexd, udev, PAM	No log review process exists	Weekly review or automated alerting
No auth.log; SSH disabled	grep auth.log; journalctl -u ssh	30 Sep – 01 Oct	rsyslog (absent), ssh	Auth evidence only in journald; SSH state not baselined	Install rsyslog or collect journald; baseline SSH

6. EVIDENCE BUNDLE 3 – LYNIS SECURITY ASSESSMENT

Lynis 3.1.4 was already installed on the machine and, as Figure 15 shows, runs on its own schedule. I ran a manual scan as well so I could watch the checks happen.

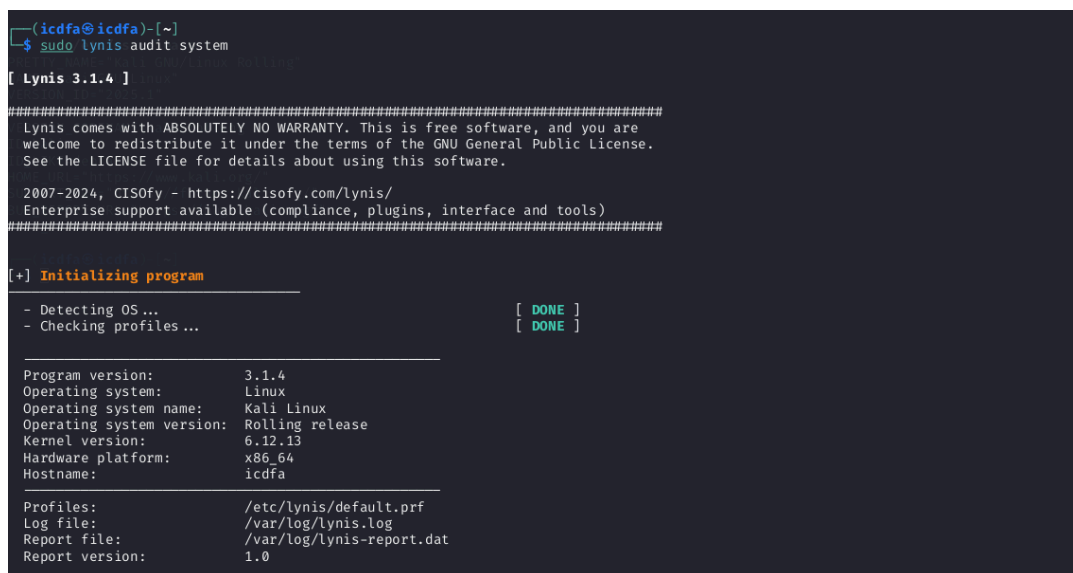
6.1 Version and execution (Activity 3.1)

```
lynis show version
sudo lynis audit system
```



```
(icdfa@icdfa)~$ lynis show version
3.1.4
(icdfa@icdfa)~$
```

Figure 20 – lynis show version: 3.1.4



```
(icdfa@icdfa)~$ sudo lynis audit system
[ Lynis 3.1.4 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2024, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
- Detecting OS... [ DONE ]
- Checking profiles... [ DONE ]

Program version: 3.1.4
Operating system: Linux
Operating system name: Kali Linux
Operating system version: Rolling release
Kernel version: 6.12.13
Hardware platform: x86_64
Hostname: icdfa

Profiles: /etc/lynis/default.prf
Log file: /var/log/lynis.log
Report file: /var/log/lynis-report.dat
Report version: 1.0
```

Figure 21 – Lynis opening banner: Kali Linux rolling, kernel 6.12.13, x86_64, host icdfa

The banner confirms the scan ran against the right host (icdfa, Kali Linux rolling release, kernel 6.12.13, x86_64) using the default profile /etc/lynis/default.prf. Results go to /var/log/lynis.log and /var/log/lynis-report.dat.

```

- Checking for system binaries that are required by Debian Tests ...
- Checking /bin ... [ FOUND ]
- Checking /sbin ... [ FOUND ]
- Checking /usr/bin ... [ FOUND ]
- Checking /usr/sbin ... [ FOUND ]
- Checking /usr/local/bin ... [ FOUND ]
- Checking /usr/local/sbin ... [ FOUND ]
- Authentication:
- PAM (Pluggable Authentication Modules):

[WARNING]: Test DEB-0001 had a long execution: 93.456509 seconds

- libpam-tmpdir [ Not Installed ]
- File System Checks:
- DM-Crypt, Cryptsetup & Cryptmount:

[WARNING]: Test DEB-0280 had a long execution: 21.005002 seconds

- Checking / on /dev/sda1 [ NOT ENCRYPTED ]
- Software:
- apt-listbugs [ Not Installed ]
- apt-listchanges [ Not Installed ]
- needrestart [ Not Installed ]
- fail2ban [ Not Installed ]
]

[+] Boot and services
- Service Manager [ systemd ]
- Checking UEFI boot [ DISABLED ]
- Checking presence GRUB2 [ FOUND ]
- Checking for password protection [ NONE ]
- Check running services (systemctl) [ DONE ]
  Result: found 19 running services
- Check enabled services at boot (systemctl) [ DONE ]

```

Figure 22 – Debian-specific tests and Boot and services

```

[+] Memory and Processes
- Checking /proc/meminfo [ FOUND ]
- Searching for dead/zombie processes [ NOT FOUND ]
- Searching for IO waiting processes [ NOT FOUND ]
- Search prelink tooling [ NOT FOUND ]

[+] Users, Groups and Authentication
- Administrator accounts [ OK ]
- Unique UIDs [ OK ]
- Consistency of group files (grpck) [ OK ]
- Unique group IDs [ OK ]
- Unique group names [ OK ]
- Password file consistency [ OK ]
- Password hashing methods [ OK ]
- Checking password hashing rounds [ DISABLED ]
- Query system users (non daemons) [ DONE ]
- NIS+ authentication support [ NOT ENABLED ]
- NIS authentication support [ NOT ENABLED ]
- Sudoers file(s) [ FOUND ]
  - Permissions for directory: /etc/sudoers.d [ WARNING ]
  - Permissions for: /etc/sudoers [ OK ]
  - Permissions for: /etc/sudoers.d/kali-grant-root [ OK ]
  - Permissions for: /etc/sudoers.d/README [ OK ]
- PAM password strength tools [ SUGGESTION ]
- PAM configuration files (pam.conf) [ FOUND ]
- PAM configuration files (pam.d) [ FOUND ]
- PAM modules [ FOUND ]
- LDAP module in PAM [ NOT FOUND ]
- Accounts without expire date [ SUGGESTION ]
- Accounts without password [ OK ]
- Locked accounts [ OK ]
- Checking user password aging (minimum) [ DISABLED ]
- User password aging (maximum) [ DISABLED ]

```

Figure 23 – Memory and processes; Users, groups and authentication

```
icdfa@icdfa: ~  
- Checking crontab and cronjob files [ DONE ]  
[+] Accounting  
- Checking accounting information [ NOT FOUND ]  
- Checking sysstat accounting data [ DISABLED ]  
- Checking auditd [ ENABLED ]  
- Checking audit rules [ OK ]  
- Checking audit configuration file [ OK ]  
- Checking auditd log file [ FOUND ]  
[+] Time and Synchronization  
n  
- Administrator accounts [ OK ]  
- Unique UIDs [ OK ]  
- Consistency of group files (grpck) [ OK ]  
- Unique group IDs [ OK ]  
- Unique group names [ OK ]  
- Password file consistency [ OK ]  
- Password hashing methods [ OK ]  
- Checking password hashing rounds [ DISABLED ]  
- Query system users (non daemons) [ DONE ]  
- NIS+ authentication support [ NOT ENABLED ]  
- NIS authentication support [ NOT ENABLED ]  
- Sudoers file(s) [ FOUND ]  
- Permissions for directory: /etc/sudoers.d [ WARNING ]  
- Permissions for: /etc/sudoers [ OK ]  
- Permissions for: /etc/sudoers.d/kali-grant-root [ OK ]  
- Permissions for: /etc/sudoers.d/README [ OK ]  
- PAM password strength tools [ SUGGESTION ]  
- PAM configuration files  
[+] Cryptography
```

Figure 24 – Accounting checks, including auditd

What the scan found so far:

- **Debian tests:** libpam-tmpdir, apt-listbugs, apt-listchanges, needrestart and fail2ban are all not installed. The root filesystem on /dev/sda1 is NOT ENCRYPTED. The two orange [WARNING] lines about DEB-0001 and DEB-0280 taking 93 and 21 seconds are only Lynis reporting slow tests, not security problems. That fits with the CPU stalls seen in Section 5.3.
- **Boot and services:** GRUB2 is present but password protection is **NONE**. UEFI boot is disabled and 19 services are running.
- **Users and authentication:** the permissions on /etc/sudoers.d are flagged in orange during the scan (it is not listed as a formal warning in the final report). Password hashing rounds and password ageing (minimum and maximum) are DISABLED. Lynis also makes SUGGESTIONS about PAM password strength tools and accounts that have no expiry date. Account basics are fine: unique UIDs, consistent group files, no accounts without a password.
- **Accounting:** process accounting is NOT FOUND and sysstat is DISABLED. auditd is ENABLED, and Lynis rates the audit rules and configuration as OK.

That last point matters. Lynis says the audit rules are OK, but Section 4.2 shows one of them never loaded. Lynis checks that rules exist; it does not check that every rule you intended is there. So this is a second tool giving false assurance about the same control, which is why W4-F01 relies on `auditctl -l` and the journal, not on the scanner.

6.2 Hardening index and summary (Activity 3.2)

My first run was interrupted with Ctrl+C at the Cryptography stage (Figure 25), before Lynis printed its final results. My first attempt to read the report file also failed with "Permission denied", because

/var/log/lynis-report.dat can only be read by root and I had left out sudo. I re-ran the full scan and saved the output to a file so the summary could be captured cleanly:

```

- Consistency of group files (grpck) [ OK ]
- Unique group IDs [ OK ]
- Unique group names [ OK ]
- Password file consistency [ OK ]
- Password hashing methods [ OK ]
- Checking password hashing rounds [ DISABLED ]
- Query system users (non daemons) [ DONE ]
- NIS+ authentication support [ NOT ENABLED ]
- NIS authentication support [ NOT ENABLED ]
- Sudoers file(s) [ FOUND ]
  - Permissions for directory: /etc/sudoers.d [ WARNING ]
  - Permissions for: /etc/sudoers [ OK ]
  - Permissions for: /etc/sudoers.d/kali-grant-root [ OK ]
  - Permissions for: /etc/sudoers.d/README [ OK ]
- PAM password strength tools [ SUGGESTION ]
- PAM configuration files [ SUGGESTION ]
[+] Cryptography
^C
Interrupt detected.
Cleaning up ... [ DONE ]

(icdfa@icdfa)-[~]
icdfa$ grep hardening_index /var/log/lynis-report.dat
grep: /var/log/lynis-report.dat: Permission denied

(icdfa@icdfa)-[~]
icdfa$ grep "warning" /var/log/lynis-report.dat
grep: /var/log/lynis-report.dat: Permission denied

(icdfa@icdfa)-[~]
icdfa$ grep "suggestion" /var/log/lynis-report.dat | head -20
grep: /var/log/lynis-report.dat: Permission denied

(icdfa@icdfa)-[~]
icdfa$

```

Figure 25 – first run interrupted at Cryptography; grep without sudo returns Permission denied

```

sudo lynis audit system --quick 2>&1 | tee ~/lynis_scan.txt
tail -45 ~/lynis_scan.txt
sudo grep "^hardening_index" /var/log/lynis-report.dat
sudo grep "^warning" /var/log/lynis-report.dat
sudo grep "^suggestion" /var/log/lynis-report.dat | head -20

```

```

(icdfa@icdfa)-[~]
icdfa$ tail -45 ~/lynis_scan.txt
Follow-up:
- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

Lynis security scan details:
Hardening index : 65 [#####]
Tests performed : 273
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Lynis 3.1.4
Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)
2007-2024, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)

```

Figure 26 – completed scan: Hardening index 65, 273 tests performed, 1 plugin

Hardening index: 65/100 from **273** tests, with **1 warning** and at least 20 suggestions (the first 20 are shown in Figure 27). I am using 70/100 as the minimum acceptable baseline for a business-critical Linux

host, so this system **does not meet** that threshold. It is five points short, which fits the picture so far: nothing is badly broken, but a lot of small controls are not in place.

One detail in the summary is easy to miss. Under Components, Lynis shows **Firewall [V]**, meaning it found firewall software. But the only warning in the report (Figure 27) is **FIRE-4512: iptables module(s) loaded, but no rules active**. The firewall is installed but does nothing, so every listening port is reachable. This is the third time in this lab that a control looked present and turned out not to be working: the audit rule in Section 4.2, the audit rules rated OK in Figure 24, and now the firewall.

```

icdfa@icdfa:~$ sudo grep "warning" /var/log/lynis-report.dat
[sudo] password for icdfa:
warning[]-FIRE-4512iptables module(s) loaded, but no rules active|---

icdfa@icdfa:~$ sudo grep "suggestion" /var/log/lynis-report.dat | head -20
suggestion[]-LYNIS[This release is more than 4 months old. Check the website or Github to see if there is an update available.]---
suggestion[]-DEB-0280Install libpam-mdm to set $TM and $TMOUT for PAM sessions|---
suggestion[]-DEB-0810Install apt-listbugs to display a list of critical bugs prior to each APT installation.|---
suggestion[]-DEB-0811Install apt-listchanges to display any significant changes prior to any upgrade via APT.|---
suggestion[]-DEB-0831Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are using old versions of libraries and need restarting.|---
suggestion[]-DEB-0880Install fail2ban to automatically ban hosts that commit multiple authentication errors.|---
suggestion[]-BOOT-5122Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password)|---
suggestion[]-BOOT-5264Determine runlevel and services at startup|---
suggestion[]-BOOT-5264Consider hardening system services|Run "/usr/bin/systemd-analyze security SERVICE" for each service|---
suggestion[]-AUTH-9230Configure password hashing rounds in /etc/login.defs|---
suggestion[]-AUTH-9262Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or libpam-passwdqc|---
suggestion[]-AUTH-9282When possible set expire dates for all password protected accounts|---
suggestion[]-AUTH-9286Configure minimum password age in /etc/login.defs|---
suggestion[]-AUTH-9286Configure maximum password age in /etc/login.defs|---
suggestion[]-AUTH-9328Default umask in /etc/login.defs could not be found and defaults usually to 022, which could be more strict like 027|---
suggestion[]-FILE-6310To decrease the impact of a full /home file system, place /home on a separate partition|---
suggestion[]-FILE-6310To decrease the impact of a full /var file system, place /var on a separate partition|---
suggestion[]-USB-1000Disable drivers like USB storage when not used, to prevent unauthorized storage or data theft|---
suggestion[]-STRG-1846Disable drivers like firewire storage when not used, to prevent unauthorized storage or data theft|---
suggestion[]-PKGS-7370Install debsums utility for the verification of packages with known good database.|---

icdfa@icdfa:~$

```

Figure 27 – the one warning (FIRE-4512) and the first 20 suggestions from /var/log/lynis-report.dat

The suggestions confirm the test IDs for what I saw during the scan: DEB-0280/0810/0811/0831/0880 (missing Debian security packages, including fail2ban), BOOT-5122 (no GRUB password), BOOT-5264 (services not hardened with systemd-analyze security), AUTH-9230/9262/9282/9286/9328 (password hashing rounds, PAM strength, account expiry, password ageing and the default umask), FILE-6310 (/home and /var not on separate partitions), USB-1000 and STRG-1846 (USB and FireWire storage drivers enabled) and PKGS-7370 (no debsums). The first line, LYNIS, says this Lynis release is more than four months old. The scanner itself should be kept up to date, or it may miss newer checks.

6.3 Selected findings

These are the results from the scan that matter most for security. Every ID below comes from Figure 27, except the *sudoers.d* and accounting items, which come from the scan screens in Figures 23 and 24.

Lynis ID	What Lynis reported	Type	Risk	Remediation	Priority
FIRE-4512	iptables module(s) loaded, but no rules active (Fig. 27)	Warning	No host firewall in practice. Every listening service is reachable from the network	<code>sudo apt install ufw, sudo ufw default deny incoming, sudo ufw default allow outgoing, sudo ufw enable</code>	HIGH
BOOT-5122	Set a password on GRUB boot loader (Fig. 22, 27)	Suggestion	Anyone at the console can change boot options and get a root shell, bypassing login	Set a GRUB password with <code>grub-mkpasswd-pbkdf2</code> and <code>update-grub</code>	MODERATE
AUTH-9230 / 9286 / 9282	Password hashing rounds, minimum and maximum password age, and account expiry not configured (Fig. 23, 27)	Suggestion	Passwords never expire and stolen hashes are cheaper to crack	Set <code>PASS_MAX_DAYS 90</code> and <code>PASS_MIN_DAYS 1</code> in <code>/etc/login.defs</code> ; apply with <code>chage</code> ; raise the hashing cost	MODERATE

Lynis ID	What Lynis reported	Type	Risk	Remediation	Priority
AUTH-9262	Install a PAM module for password strength testing (Fig. 27)	Suggestion	Weak passwords are accepted	Install libpam-pwquality and set minimum length and complexity	MODERATE
DEB-0880	Install fail2ban (Fig. 15, 27)	Suggestion	Nothing blocks repeated authentication failures. Links to W4-F03	Install fail2ban if SSH is ever enabled; meanwhile alert on sudo failures	MODERATE
Scan check (Fig. 23)	Permissions for /etc/sudoers.d flagged during scan	Scan flag	Loose permissions on the folder that grants sudo rights	<code>sudo chmod 750 /etc/sudoers.d</code> ; check with <code>ls -ld /etc/sudoers.d</code>	MODERATE
USB-1000 / STRG-1846	Disable USB and FireWire storage drivers when not used (Fig. 27)	Suggestion	Data can be copied off, or malware brought in, on removable media	Blacklist usb-storage and firewire modules where not needed	LOW
Scan checks (Fig. 22, 24)	Root disk NOT ENCRYPTED; process accounting and sysstat disabled	Info	Data readable if the disk is copied; less history for investigations	Accept for the lab with sign-off; enable sysstat	LOW

6.4 Hardening action and retest (Activity 3.3)

I picked the firewall for the retest. It was the only formal Lynis warning, it is a preventive control rather than a detective one, and the result can be checked directly with Lynis.

Before

```
(icdfa@icdfa)-[~]
$ sudo iptables -L -n
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination

(icdfa@icdfa)-[~]
$
```

Figure 28 – BEFORE: `iptables -L -n` shows INPUT, FORWARD and OUTPUT all set to policy ACCEPT with no rules

All three chains are set to ACCEPT and contain no rules, which is exactly what FIRE-4512 described. Any service that started listening on this machine would be reachable from the network.

Change

```
sudo apt install -y ufw
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw enable
sudo ufw status verbose
```

```
(icdfa@icdfa)-[~]
$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)

(icdfa@icdfa)-[~]
$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)

(icdfa@icdfa)-[~]
$ sudo ufw enable
Firewall is active and enabled on system startup

(icdfa@icdfa)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

(icdfa@icdfa)-[~]
$
```

Figure 29 – ufw configured: Status active, Logging on (low), Default deny (incoming), allow (outgoing), disabled (routed)

Installing ufw also created `/etc/systemd/system/multi-user.target.wants/ufw.service`, so the firewall starts at boot. `ufw enable` confirmed "Firewall is active and enabled on system startup", and the status now shows default deny for incoming traffic, allow for outgoing traffic, routing disabled and logging on.

After

```
sudo lynis audit system --quick 2>&1 | tee ~/lynis_after.txt
```

```
icdfa@icdfa: ~  
* Website: https://cisofy.com/lynis/controls/ACCT-9626/  
* Determine if automation tools are present for system management [TOOL-5002]  
- Related resources  
* Website: https://cisofy.com/lynis/controls/TOOL-5002/  
* Consider restricting file permissions [FILE-7524]  
- Details : See screen output or log file  
- Solution : Use chmod to change file permissions  
- Related resources  
* Website: https://cisofy.com/lynis/controls/FILE-7524/  
* Double check the permissions of home directories as some might be not strict enough. [HOME-9304]  
- Related resources  
* Website: https://cisofy.com/lynis/controls/HOME-9304/  
* One or more sysctl values differ from the scan profile and could be tweaked [KRNL-6000]  
- Solution : Change sysctl value or disable test (skip-test=KRNL-6000:<sysctl-key>)  
- Related resources  
* Article: Linux hardening with sysctl settings: https://linux-audit.com/linux-hardening-with-sysctl/  
* Article: Overview of sysctl options and values: https://linux-audit.com/kernel/sysctl/  
* Website: https://cisofy.com/lynis/controls/KRNL-6000/  
* Harden compilers like restricting access to root user only [HRDN-7222]  
- Related resources  
* Article: Why remove compilers from your system?: https://linux-audit.com/software/why-remove-compilers-from-your-system/  
* Website: https://cisofy.com/lynis/controls/HRDN-7222/  
  
Follow-up:  
- Show details of a test (lynis show details TEST-ID)  
- Check the logfile for all details (less /var/log/lynis.log)  
- Read security controls texts (https://cisofy.com)  
- Use --upload to upload data to central system (Lynis Enterprise users)  
  
=====
```

```
Lynis security scan details:  
  
Hardening index : 67 [#####] ]  
Tests performed : 273  
Plugins enabled : 1  
  
Components:  
- Firewall [V]  
- Malware scanner [V]  
  
Scan mode:  
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]  
  
Lynis modules:  
- Compliance status [?]   
- Security audit [V]  
- Vulnerability scan [V]  
  
Files:  
- Test and debug information : /var/log/lynis.log  
- Report data : /var/log/lynis-report.dat  
  
=====
```

```
Lynis 3.1.4  
  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
  
2007-2024, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
  
=====
```

```
[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)  
  
(icdfa@icdfa)-[~]  
$ tail -45 ~/lynis_aftertxt  
tail: cannot open '/home/icdfa/lynis_aftertxt' for reading: No such file or directory  
  
(icdfa@icdfa)-[~]
```

Figure 30 – AFTER: Lynis rescan, hardening index 67 from 273 tests

The rescan ran the same 273 tests and the hardening index rose from **65 to 67**. The firewall was the only thing I changed between the two scans, so the two points come from FIRE-4512 being resolved. The score is still below the 70 baseline, which is expected: the boot loader, password policy and PAM items in Section 6.3 are still open, and they are scheduled in the remediation plan. (My first attempt to view the saved file failed because I typed `lynis_aftertxt` without the dot, but the full scan output on screen already shows the result.)

Control objective achieved: the host now enforces a default-deny policy for inbound traffic at boot, so services are no longer reachable from the network unless they are explicitly allowed. This turns the firewall from installed-but-empty into an enforcing control and clears the only Lynis warning.

Operational impact: no disruption on this lab machine, because no inbound services are needed (SSH is disabled). On a production server the same change could cut off remote access or a business service, so it would go through change management first: list the required ports, add allow rules such as `sudo ufw allow 22/tcp` before enabling, agree a maintenance window and keep a rollback plan (`sudo ufw disable`). The audit rules fix from W4-F01 is the next change to make; the corrected rule set is in the remediation plan.

```
# Planned next change (W4-F01): corrected /etc/audit/rules.d/custom.rules
-w /etc/passwd -p wa -k passwd_changes
-w /etc/shadow -p rwa -k shadow_changes
-a always,exit -F arch=b64 -S execve -F auid>=1000 -F auid!=unset -k
program_execution
-a always,exit -F arch=b32 -S execve -F auid>=1000 -F auid!=unset -k
program_execution
-w /var/log/journal/ -p wa -k log_tamper
# then: sudo augenrules --check && sudo augenrules --load && sudo auditctl -l
```

7. EVIDENCE BUNDLE 4 – CONTROL MONITORING AND GOVERNANCE

7.1 Control-monitoring table

Each row below is one control, how I tested it, its current state and how we would know it stays fixed. The Status column reflects what the evidence shows, not what the configuration is supposed to do.

Control objective	Evidence source	Owner	Observed status	KPI / KRI / threshold	Security significance	Remediation	Retest
Kernel auditing active at boot	systemctl status auditd	SysAdmin	Compliant – active, enabled, PID 9660	auditd up 99.9% of time; alert if stopped >5 min	Without it there is no record of privileged actions	Keep enabled; alert on service stop	After every reboot; monthly
All required audit rules loaded	auditctl -l; journalctl (audit-rules.service)	SysAdmin / SOC	Partial – 4 of 5 rules; service failed 13:00:11	100% of baseline rules loaded; 0 audit-rules.service failures	Silent failure means no audit trail for log tampering	Fix syntax; replace auth.log watch with /var/log/journal/	Re-check rule count after next reboot and monthly
Privileged actions traceable to a person	ausearch -k passwd_changes	SOC	Compliant – auid=1000 recorded for euid=0 actions	100% of root actions carry a real auid	Supports accountability and investigations	Narrow passwd watch to -p wa to cut noise	Quarterly rule review
Failed privilege use detected and reviewed	journalctl -p err (sudo)	IAM / SecOps	Not compliant – 3 failed sudo attempts (17 Jul) never reviewed	Alert on ≥3 sudo failures in 10 min; 100% reviewed within 24 h	Undetected account misuse or brute force	Forward journald auth events to SIEM; create alert rule	Controlled test of 3 wrong passwords within 7 days
Logs reviewed and errors actioned	journalctl -p err wc -l	SysAdmin / SOC	Not compliant – 222 errors, Apr–Oct, unreviewed	0 error entries older than 30 days without review or accepted exception	Real events get lost among routine noise	Weekly review; fix or formally accept recurring errors	Re-run count in 30 days
Authentication log available to collectors	ls /var/log/auth.log; journalctl	SysAdmin	Gap – no auth.log, rsyslog absent	Auth events reach SIEM within 5 min	Collectors expecting auth.log get nothing	Install rsyslog or configure journald collection	Confirm events in SIEM after change
Remote access baselined	systemctl status ssh; journalctl -u ssh	SysAdmin	Compliant – SSH disabled, 0 events	Any change to ssh enabled state triggers alert	Unapproved SSH would open remote access	Record disabled state in baseline	Monthly configuration check

Control objective	Evidence source	Owner	Observed status	KPI / KRI / threshold	Security significance	Remediation	Retest
Host hardening baseline	sudo lynis audit system (Fig. 26, 30)	Security Eng / CISO	Not compliant – 65/100 before, 67/100 after firewall fix	Hardening index ≥70; high warnings closed in 30 days	Many small weaknesses together make it easier to get and keep root access	Work through remaining Lynis items in priority order; document accepted exceptions	Rescan after fixes; quarterly
Host firewall enforcing default-deny	Lynis FIRE-4512 (Fig. 27); iptables -L -n (Fig. 28); ufw status (Fig. 29)	SysAdmin / Network Sec	Remediated during lab – was no rules; now ufw active, default deny inbound	Firewall active with default-deny inbound; 0 unapproved open ports	Before the fix, all listening services were exposed	Done: ufw enabled at boot. Keep a list of approved ports	Retested 01 Oct: index 65 → 67. Check ufw status monthly

7.2 Governance questions

1. Which finding needs attention first, and why?

Two findings share the top spot, for different reasons. The empty firewall (FIRE-4512, part of W4-F04) was the most urgent preventive fix, because it affects what an attacker can reach. It took minutes to correct, so I fixed it during the lab (Section 6.4). Among the monitoring findings, W4-F01, the partly loaded audit rule set, comes first. The other monitoring findings are about events being missed. This one is worse because the control reports itself as healthy while part of it is not working. False assurance is more dangerous than a known gap, since nobody goes looking for a problem they think is already solved. It is also the cheapest to fix: one corrected file and a reload.

2. Who should own remediation?

The System Administrator owns the auditd rules, rsyslog/journald configuration and the recurring system errors. The SOC owns the alert rules and the weekly log review. The IAM team owns the sudo policy and follow-up on failed privilege attempts. Security Engineering owns the Lynis baseline, and the CISO signs off on any finding we decide to accept rather than fix.

3. When should this escalate beyond the technical team?

Escalate to the CISO or risk committee if: auditd or audit-rules.service is down for more than an hour on a production host; failed sudo attempts are not explained by the account owner within 24 hours; /etc/shadow is written outside an approved change window; any log file or journal is deleted or truncated; or the Lynis hardening index drops by 10 points or more between scans.

4. What evidence would prove remediation worked?

`auditctl -l` listing every baseline rule after a reboot, with audit-rules.service showing active. A deliberate test of three wrong sudo passwords producing an alert in the SIEM. A `journalctl -p err` count with no unexplained entries older than 30 days. `sudo ufw status verbose` showing default-deny, and a Lynis rescan with FIRE-4512 gone and the index above 65, working towards 70.

5. When should each control be retested?

High findings within 7 days of the fix. Moderate findings within 30 days. Audit rule count after every reboot and once a month. Log error review weekly. Full Lynis rescan quarterly and after any major change.

8. EVIDENCE BUNDLE 5 – SIEM, AUTOMATION AND CONTINUOUS MONITORING

Everything in this report was collected by hand, from one terminal, on one machine. That is fine for a lab, but it does not scale, and it is why the July sudo failures went unseen for two and a half months. The table below shows how each evidence source would feed a SIEM so the same checks happen automatically.

8.1 Evidence-to-SIEM mapping

Evidence source	How it gets to the SIEM	Events	Detection use case	Alert level	CCM use
auditd (/var/log/audit/audit.log)	auditd plugin (af_unix/syslog), Auditbeat, or Wazuh agent. Currently none configured ("No plugins found")	SYSCALL, PATH, EXECVE, CONFIG_CHANGE	Writes to /etc/passwd or /etc/shadow; audit rule changes; root commands by unexpected users	HIGH: shadow write. CRITICAL: auditd stopped or rules removed	Proves privileged-access control is working
systemd journal (auth events)	Wazuh/Elastic agent reading journald, or rsyslog forwarding	sudo, PAM, sshd, lightdm	≥3 failed sudo attempts; root login; logins outside hours	HIGH: repeated sudo failure	Authentication KRI trend
systemd journal (errors)	Same agent, priority ≤3 filter	kernel, systemd unit failures	audit-rules.service failed; soft lockups; services crashing	HIGH: audit unit failure. MODERATE: other unit failures	Log review KPI; availability
Unit state	Agent command check / systemctl is-enabled	ssh, auditd enabled state	SSH unexpectedly enabled; auditd disabled	HIGH	Configuration drift
Lynis (lynis-report.dat)	Existing lynis.service/timer, report parsed and ingested	hardening_index, warning[], suggestion[]	New warning; index drops	HIGH: new warning. CRITICAL: drop ≥10	Hardening baseline trend

8.2 Operational alert vs governance escalation

Not every alert needs to reach management. The SOC handles the first column day to day; the second column is when it becomes a governance matter.

Condition	Operational alert (SOC / admin)	Governance escalation (CISO / risk)
3 failed sudo attempts in 10 min	Yes. Confirm with the account owner	Only if unexplained after 24 h
audit-rules.service fails or rule count drops	Yes. Fix and reload immediately	Yes, on production, because audit evidence was incomplete
auditd stopped	Yes. Auto-restart and investigate	Yes, if longer than 1 hour
/etc/shadow written outside a change window	Yes. Open an incident	Yes. Possible credential compromise
Journal or log files deleted / truncated	Yes. Preserve what remains	Yes. Possible evidence tampering
Recurring error not reviewed in 30 days	Weekly review ticket	Reported as a KPI breach in the monthly control report

Condition	Operational alert (SOC / admin)	Governance escalation (CISO / risk)
Lynis index drops ≥ 10 points	Security Engineering investigates	Yes. Control regression

8.3 Continuous control monitoring flow

```

Linux host (icdfa)
  auditd + systemd journal + Lynis timer
    |
    v
  agent (Wazuh / Elastic Agent) or audisp + rsyslog forwarding
SIEM
- Alerts:      sudo failures, audit-rules failure, shadow write, SSH enabled
- Dashboards: failed auth trend, error backlog age, hardening index over time
- Reports:    weekly log review, monthly control status
    |
    v
  ticketing / SOAR
GRC platform: control status updated from evidence, not from self-assessment
    |
    v
CISO / risk committee dashboard

```

The point of this design is that each row in the Section 7 table gets measured by the SIEM every day, instead of once a term by an analyst at a terminal. A failed audit-rules.service would raise a ticket the same morning instead of sitting in the journal. The control status the risk committee sees would come straight from machine evidence.

9. EVIDENCE BUNDLE 6 – FINDINGS, REMEDIATION AND CONCLUSION

9.1 Formal finding records

Finding W4-F01: audit rule set only partly loaded

Date / time observed	01 October 2026, 13:00:11 WAT
Evidence source	auditctl -l (Fig. 4); custom.rules (Fig. 3); journalctl -p err (Fig. 17); systemctl status auditd (Fig. 2); Lynis ACCT checks (Fig. 24)
Evidence summary	auditd 4.1.2 active and enabled (PID 9660). audit-rules.service logged "Failed to start ... Load Audit Rules" at 13:00:11. auditctl -l lists 4 rules; the auth.log watch is missing because of a "-pa" typo and because the file does not exist on Kali. No audisp plugin, so events stay on the host.
Security significance	False assurance: the service looks healthy, but changes to logs are not audited. Local-only storage also means an attacker with root access could delete the audit trail.
Control objective	All baseline audit rules load successfully at boot and audit records are kept where they cannot be quietly altered.
Control owner	System Administrator (rules), SOC (monitoring)
Priority	HIGH
Recommended action	Correct custom.rules as shown at the end of Section 6.4; watch /var/log/journal/; filter execve to real users; alert on audit-rules.service failure; configure forwarding.
Retest evidence	auditctl -l shows all rules after a reboot; audit-rules.service active; ausearch -k log_tamper returns an event after a test write.

Finding W4-F02: no log review or error monitoring

Date / time observed	30 Sep – 01 Oct 2026 (entries dated Apr – Oct 2026)
Evidence source	journalctl -p err wc -l (Fig. 18); head/tail (Fig. 16–17); awk source count (Fig. 19); journal grep for Lynis runs (Fig. 15)
Evidence summary	222 error-level entries. Kernel accounts for 104 (vmwgfx, RCU stalls, soft lockups up to 35 s, including one on 01 Oct 09:15:26). obexd, systemd-udev and lightdm/PAM errors repeat at every boot. The same errors repeat for months, with no sign anyone reviewed them. Timestamps are out of order.
Security significance	Without review, real security events (W4-F01, W4-F03) sit unnoticed among routine errors. Soft lockups can also cause gaps in logging.
Control objective	Error-level events are reviewed within a set timeframe and are either fixed or formally accepted.
Control owner	System Administrator / SOC
Priority	HIGH
Recommended action	Weekly review (or SIEM alerting) of priority ≤ 3 events. Fix the udev rule, disable obexd, check VM CPU resources and guest tools, check time sync with timedatectl. Document accepted VM noise.
Retest evidence	In 30 days: journalctl -p err shows no new unexplained entries, and the review record shows dates and who reviewed.

Finding W4-F03: failed privilege escalation not detected

Date / time observed	17 July 2026, 20:57:44 WAT (found 30 Sep 2026)
Evidence source	journalctl -p err (Fig. 17); journalctl _COMM=sudo (Fig. 14); Lynis DEB-0880 (Fig. 15, 22)
Evidence summary	sudo[73686]: icdfa, 3 incorrect password attempts, TTY=pts/1, PWD=/home/icdfa/GRC101_Lab/03_GRC_Evidence_Folder, USER=root. No alert, no review, no auth.log. Found by chance 75 days later.
Security significance	Repeated failed sudo attempts are an early sign that someone is misusing or guessing an account. Here it was almost certainly the account owner, but the system had no way to know that.
Control objective	Failed privilege-use attempts are detected and reviewed within 24 hours.
Control owner	IAM team / Security Operations
Priority	MODERATE (lab); HIGH on a multi-user or production host
Recommended action	Forward journald auth events (or install rsyslog for auth.log) to SIEM; alert on ≥ 3 sudo failures in 10 minutes; consider pam_faillock lockout; record a review of each alert.
Retest evidence	Controlled test of 3 wrong sudo passwords produces an alert and a ticket within 5 minutes.

Finding W4-F04: hardening below baseline, no active firewall

Date / time observed	01 October 2026 (manual run); scheduled runs on 29 Sep, 30 Sep and 01 Oct 2026
Evidence source	sudo lynis audit system (Fig. 20–26); /var/log/lynis-report.dat (Fig. 27); journalctl (Fig. 15)
Evidence summary	Lynis 3.1.4 on Kali rolling, kernel 6.12.13. Hardening index 65/100 from 273 tests. One warning: FIRE-4512, iptables loaded but no rules active, even though the summary lists the firewall as present. Suggestions include BOOT-5122 (no GRUB password), AUTH-9230/9262/9282/9286 (password hashing, strength, expiry and ageing), DEB-0880 (fail2ban), USB-1000 and STRG-1846 (removable storage drivers). /etc/sudoers.d permissions flagged during the scan. Root disk not encrypted. auditd ENABLED with rules rated OK (see W4-F01).
Security significance	No single item is critical, but together they make it easier to gain or keep root access: through sudo configuration, the boot loader, or weak and permanent passwords. Lynis has been flagging some of these every day without action.
Control objective	The host meets the agreed hardening baseline (Lynis index ≥ 70) and high-risk warnings are closed within 30 days.
Control owner	Security Engineering / CISO for exceptions
Priority	HIGH (firewall); MODERATE (other items)
Recommended action	Enable ufw with default-deny inbound; set a GRUB password; configure password ageing, hashing cost and libpam-pwquality; chmod 750 /etc/sudoers.d; update Lynis; record accepted exceptions (disk encryption in the lab) with sign-off.
Retest evidence	Firewall retested 01 Oct 2026: ufw status shows active, default deny (incoming) (Fig. 29); Lynis rescan index rose from 65 to 67 (Fig. 30). Remaining items: rescan after the 30-day fixes, target index ≥ 70 .

9.2 Remediation and retest plan

ID	Action	Owner	Due	Priority	Retest date	Success criteria
F01	Fix custom.rules, watch /var/log/journal/, filter execve, reload, alert on unit failure	SysAdmin	48 hours	HIGH	05 Oct 2026	All rules listed after reboot; audit-rules.service active
F01b	Configure audit forwarding and review auditd.conf log rotation	SysAdmin / SOC	14 days	MODERATE	16 Oct 2026	Audit events visible off-host; rotation sized for volume
F02	Start weekly error review; fix udev rule; disable obexd; check VM resources and time sync	SysAdmin	7 days	HIGH	09 Oct 2026, then 01 Nov 2026	No unexplained errors older than 30 days; review log kept
F03	Send auth events to SIEM; alert on ≥ 3 sudo failures; evaluate pam_faillock	IAM / SecOps	7 days	MODERATE	09 Oct 2026	Test failures generate alert within 5 minutes
F04a	Enable ufw default-deny inbound; allow only approved ports	SysAdmin	Done 01 Oct	HIGH	Retested 01 Oct 2026	Done: ufw active; index 65 $\rightarrow$ 67
F04b	GRUB password; password ageing and hashing cost; libpam-pwquality; sudoers.d permissions	Security Eng / IAM	30 days	MODERATE	02 Nov 2026	Rescan shows items resolved; index ≥ 70

9.3 Conclusion

Before this lab I would have looked at "auditd: active (running)" and called the control done. The evidence says otherwise. Part of the rule set never loaded. Months of errors sat in the journal without anyone reading them. A failed attempt to get root access was only found because I went looking for something else. None of this needed an attacker. All of it comes from monitoring that was switched on but never checked.

That is the main governance lesson. A control is only as good as the evidence that it is working. Turning the findings into a control-monitoring table gives each one an owner, a measurable threshold and a retest date. Feeding auditd, the journal and Lynis into a SIEM is what turns a one-off lab check into continuous assurance. Lynis gave the host a hardening index of 65/100, below the 70 baseline. It also found that the firewall was installed but had no rules, while listing it as present. I fixed that during the lab and the index rose to 67. Lynis also rated the audit rules OK even though one was missing. With the remediation plan above, the three monitoring findings can be closed within a week and verified with the retest criteria in Section 9.1.

Overall posture: NEEDS IMPROVEMENT, with a clear and achievable path to an acceptable baseline.

APPENDIX – EVIDENCE INDEX

Screenshots are placed in the sections where they are discussed. This index maps each one to the lab activity it supports. Every screenshot shows the icdfa@icdfa prompt so the host can be identified.

Ref	Activity	Evidence	Location	Status
Fig. 1	Scope	cat /etc/os-release	§2	Included
Fig. 2	1.1	systemctl status auditd	§4.1	Included
Fig. 3–4	1.2	custom.rules; auditctl -l (4 rules)	§4.2	Included
Fig. 5–6	1.3	ausearch -k passwd_changes; -k program_execution	§4.3	Included
Fig. 7–9	1.4	aureport, --failed, --login	§4.4	Included
Fig. 10–13	2.1	journalctl today; ssh and sshd entries; systemctl status ssh	§5.1	Included
Fig. 14–15	2.2	journalctl _COMM=sudo; grep authentication	§5.2	Included
Fig. 16–19	2.3	journalctl -p err, count, sources	§5.3	Included
Fig. 20–25	3.1	Lynis version, banner, test sections, interrupted run	§6.1–6.2	Included
Fig. 26–27	3.2	Completed scan summary (index 65); warning and suggestions	§6.2	Included
Fig. 28–30	3.3	Firewall before (iptables), change (ufw), after (Lynis 67)	§6.4	Included